

16 ABRIL 2026



COLOMBIA – PERÚ - CHILE

POLÍTICA CORPORATIVA DE USO Y GOBIERNO DE IA (MULTI-LLM)

BODYTECH S. A

Alcance: Esta política es de cumplimiento obligatorio para todos los empleados y colaboradores de la organización.

1. Modelo de Gobierno y Plataformas Aprobadas El gobierno de Inteligencia Artificial en la organización se divide en dos modelos de consumo, los cuales determinan los protocolos de seguridad aplicables:

- **Uso Interactivo (SaaS):** Interacción directa a través de interfaces de chat. Restringido a las plataformas corporativas aprobadas: Claude Teams, ChatGPT (Business/Enterprise) y Gemini (Google Workspace). El acceso debe realizarse obligatoriamente mediante credenciales corporativas (SSO + MFA).
- **Uso Programático (APIs):** Integraciones, microservicios y automatizaciones. Restringido a Anthropic (Claude API), OpenAI (GPT API) y Google (Gemini API). Este uso representa el mayor riesgo técnico y financiero, y está estrictamente sujeto a los controles de los apartados siguientes.

2. Control de Acceso y Arquitectura (APIs) El acceso a modelos de IA mediante API está controlado de la siguiente manera:

- **Prohibiciones:** Queda estrictamente prohibido el consumo directo de APIs desde el *frontend* o la ejecución desde *scripts* no centralizados.
- **AI Gateway (Obligatorio):** Todo consumo programático debe canalizarse a través de un proxy central (AI Gateway). Este componente es responsable de: ofuscar las llaves de acceso, validar identidades, aplicar limitación de peticiones (*rate limiting*), registrar auditorías y aplicar políticas de Prevención de Pérdida de Datos (DLP) para bloquear PII o datos financieros.
- **Stack Sugerido:** API Gateway, AWS Lambda, AWS Bedrock (cuando aplique), AWS Secrets Manager y Amazon CloudWatch.

3. Gestión Crítica de Secretos (API Keys) La exposición de credenciales representa un riesgo crítico. Se establecen las siguientes normativas:

- **Prohibición de "Hardcoding":** Las *API Keys* nunca deben codificarse de forma rígida en el código fuente, compartirse por medios no seguros, ni publicarse en repositorios (ej. GitHub).
- **Gestión Segura:** Es obligatorio almacenar las llaves en bóvedas de secretos (ej. AWS Secrets Manager o Parameter Store).
- **Aislamiento y Rotación:** Las credenciales deben aislarse por servicio, ambiente (Dev/QA/Prod) y equipo. La rotación periódica automática es obligatoria.
- **Consumo Exclusivo por Backend:** Las credenciales nunca deben llegar al cliente final ni al navegador; únicamente el *backend* está autorizado para firmar peticiones hacia los proveedores de IA.

4. Control de Consumo (FinOps) y Trazabilidad Para prevenir sobre costos y garantizar un uso racional:

- **Límites y Presupuestos:** Se definirán presupuestos por área y cuotas (límites de *tokens*) por usuario, equipo y servicio.

- **Monitoreo y Alertas:** El sistema registrará el consumo de *tokens* y costos. Se activarán alertas automáticas ante anomalías (ej. picos de consumo, horarios inusuales o peticiones desde IP/servicios no registrados).
- **Auditoría:** Todo registro en bitácora (*log*) debe incluir: identificador del usuario/servicio origen, aplicación, modelo utilizado, volumen de *tokens* y tipo de operación.

5. Incumplimientos y Medidas Disciplinarias Cualquier desvío a esta política será considerado una violación a la seguridad de la información de la empresa. Serán motivo de sanción disciplinaria:

- Utilizar recursos corporativos de IA (cuentas o APIs) para fines personales, proyectos *freelance* o de terceros.
- La exposición, ya sea accidental o intencional, de credenciales o *API Keys*.
- El uso de arquitecturas alternativas (*Shadow IT*) que evadan el AI Gateway, el SSO o los canales auditados por la organización.

Revisado por:

David Cadena

David Cadena

Gerente de Infraestructura y Ciberseguridad

Aprobado por:

Rafael Socarras

Rafael Socarras

Vicepresidente de Tecnología

Registro de auditoría

Detalles

NOMBRE DEL ARCHIVO Política Corporativa de Uso y Gobierno de IA (Multi-LLM)

ESTADO ● Firmado

MARCA DE TIEMPO DEL ESTADO 2026/04/16
19:16:30 UTC

Actividad

 ENVIADO	juan.espinosa@bodytechcorp.com envió una solicitud de firma a: • David Cadena (david.cadena@bodytechcorp.com) • Rafael Socarras (consultor.tecnologia.vp@bodytechcorp.com)	2026/04/16 17:32:38 UTC
 FIRMADO	Firmado por Rafael Socarras (consultor.tecnologia.vp@bodytechcorp.com)	2026/04/16 19:16:30 UTC
 FIRMADO	Firmado por David Cadena (david.cadena@bodytechcorp.com)	2026/04/16 17:33:58 UTC
 COMPLETADO	Este documento tiene la firma de todos los firmantes y está completo	2026/04/16 19:16:30 UTC

Es posible que la dirección de correo electrónico que se indicó anteriormente para cada firmante esté asociada a una Cuenta de Google, y puede ser la dirección de correo electrónico principal o la secundaria asociada a esa cuenta.